Lab 3

Incident Response Playbook for DDoS Attack (E-Commerce Scenario)

Inputs

DDoS Attack Scenario

An e-commerce website hosting an online sale, experiences a sudden surge in malicious traffic targeting critical application endpoints such as login, product search, cart, and checkout. The attack originates from a distributed botnet and aims to exhaust server resources, making the website unavailable to legitimate customers.

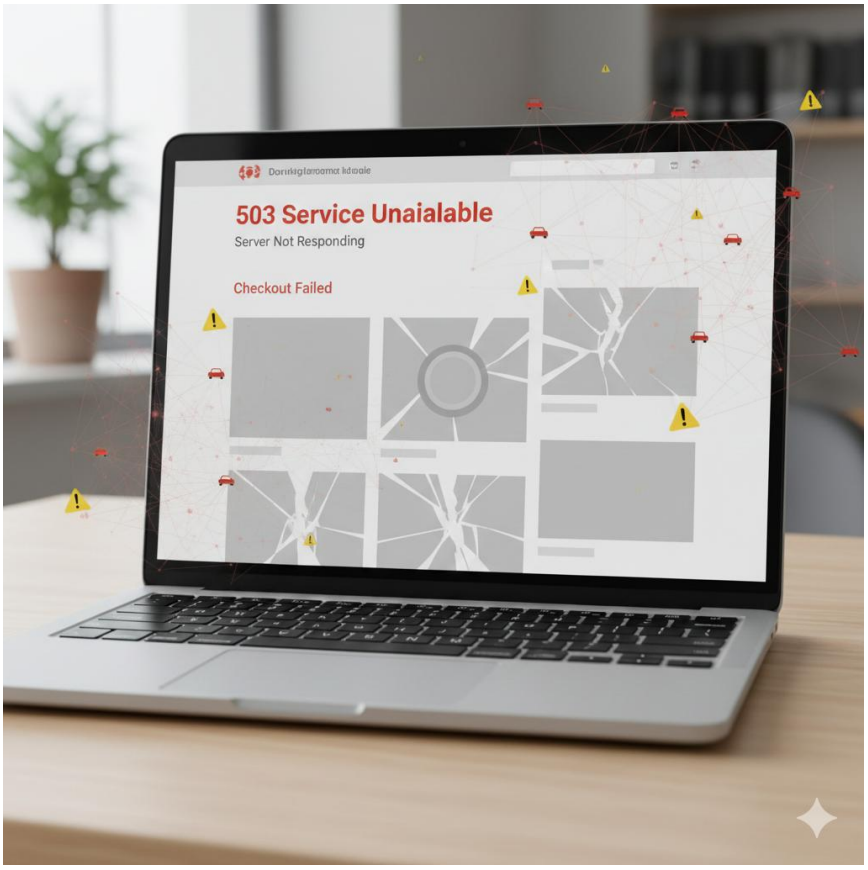

Figure: User View of E-Commerce Website During a Denial-of-Service Attack

Network Architecture

The e-commerce infrastructure consists of:

- Internet-facing web server hosting the application
- Firewall and edge router for traffic filtering
- Load balancer distributing incoming requests
- Intrusion Detection/Prevention System (IDS/IPS)
- Security Information and Event Management (SIEM) system for monitoring and logs

Figure: Network Architecture for DDoS Incident Response

Tools Used

- Text Editor – to document the incident response playbook
- Diagram Tools – to create the network architecture and attack flow diagram

Dataset Required

Sample DDoS Indicators, including:

- Sudden spike in HTTP/HTTPS requests
- Multiple requests from thousands of unique IP addresses
- Repeated access to checkout and login endpoints
- High CPU and memory utilization on web servers
- Increased number of incomplete or timed-out sessions

Brief Theory

An Incident Response Playbook is a predefined set of procedures designed to guide security teams during cyber incidents.
For DDoS attacks on e-commerce platforms, a playbook ensures rapid detection, coordinated mitigation, reduced downtime, and minimal business impact, especially during high-traffic events such as online sales.

Procedure

Step 1: Define Detection Criteria

The following criteria are used to detect a DDoS attack:

- Incoming traffic exceeds normal baseline thresholds
- Abnormal increase in requests per second to critical endpoints
- IDS/IPS alerts for application-layer flooding
- SIEM correlation of traffic spikes with service degradation

Step 2: Identify Mitigation Steps

Immediate mitigation actions include:

- Enabling rate limiting on login and checkout endpoints
- Blocking IP addresses or ranges generating excessive requests
- Activating Web Application Firewall (WAF) rules
- Redirecting traffic through cloud-based DDoS protection services
- Temporarily disabling non-essential website features

Step 3: Assign Roles

Clear role assignment ensures effective response:

- Incident Response Lead – coordinates the overall response
- Security Analyst – analyzes traffic patterns and attack indicators
- Network Administrator – applies firewall and routing controls
- System Administrator – ensures server stability and performance
- Management Team – handles communication with stakeholders

Step 4: Define Recovery Actions

Once the attack subsides:

- Gradually restore normal traffic rules
- Re-enable all e-commerce functionalities
- Verify successful transactions and payment processing
- Monitor system performance for residual attack traffic
- Confirm system integrity and data consistency

Step 5: Document Post-Incident Review Steps

After incident closure:

- Perform root cause analysis of the attack
- Document the incident timeline and response effectiveness
- Identify gaps in detection or mitigation
- Update the DDoS response playbook
- Recommend improvements such as auto-scaling and always-on DDoS protection

Conclusion

Implementing a scenario-based DDoS Incident Response Playbook for an e-commerce website significantly reduces service disruption and financial loss during attacks. Predefined detection criteria, mitigation steps, and recovery actions enable a swift and coordinated response, ensuring business continuity during critical sales periods.